

1/58



File No.: EXP202301118

RESOLUTION OF TERMINATION OF THE PROCEDURE BY VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On January 22, 2024, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against CAJASIETE, CAJA RURAL SOCIEDAD COOPERATIVA DE CREDITO (hereinafter the claimed party). The agreement to initiate was notified, and after analyzing the allegations presented, on December 3, 2024, the proposed resolution was issued, which is transcribed below:

<<

File No.: EXP202301118

PROPOSED RESOLUTION OF SANCTIONING PROCEDURE

From the procedure initiated by the Spanish Agency for Data Protection and based on the following:

BACKGROUND

FIRST: On December 13, 2022, a security breach of personal data of the entity belonging to the GRUPO CAJA RURAL: CAJASIETE, CAJA RURAL S.C.C., with NIF (...) (hereinafter CAJASIETE or the entity) was notified as the data controller. It should be noted that, as a result of notifications to the Division of Technological Innovation of this Agency regarding the personal data breach in various Entities of the aforementioned Group, including the claimed party, related to a cyber-incident, the General Subdirectorate of Data Inspection was ordered to carry out the appropriate preliminary investigations to determine a possible violation of data protection regulations.

1. Initially, the notifications of the breach were made by the data processor RURAL SERVICIOS INFORMÁTICOS S.L. (hereinafter RSI), concerning 19 entities of the Group:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/58

2. The initial notification and additional notification dates are: December 12, 2022, and January 10, 2023.

3. However, on December 13, 2022, December 14, 2022, and December 15, 2022, notifications of the breach were made by another 7 entities of the group, in their capacity as data controllers, despite the fact that the data processor is the same.

The breach notification forms are accompanied by the Security Incident Report prepared in all cases by RSI, the data processor.

- Date of breach detection: December 9, 2022

- Date of breach occurrence: November 10, 2022

- Summary of the notification:

(...)

- Type of affected data:

(...)

- Approximate number of individuals whose personal data is collected, stored, or otherwise processed exclusively related to the processing in which the breach occurred, No. of individuals 178,897.

- Approximate number of individuals whose data has been affected by the breach, No. affected (...).

- No. communicated (...).

SECOND: As a result of the notifications to the Division of Technological Innovation of this Agency regarding the personal data breach in various Entities of the GRUPO CAJA RURAL related to a cyber-incident, the General Subdirectorate of Data Inspection is ordered to carry out the appropriate preliminary investigations to determine a possible violation of data protection regulations.

During the present proceedings, the following entities have been investigated:

- CAJASIETE, with NIF (...) with address at (...) 38003-SANTA CRUZ DE TENERIFE (CANARY ISLANDS).

And 25 other entities belonging to the GRUPO CAJA RURAL, as well as RSI in its capacity as data processor.

In order to investigate the occurrence of the described facts, on March 29, 2023, a request for information was made to RSI. The response to the request was received on April 14, 2022.

On May 12, 2023, and September 27, 2023, RSI was requested to expand the information provided, and on May 26, 2023, and October 11, 2023, responses were received at the electronic headquarters of the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/58

In order to introduce the applications compromised in the breach that will be referenced throughout this report, the description included in the documentation provided by RSI in the context of the investigation proceedings is reproduced below:

(...)

Furthermore, RSI, in its document received at the AEPD on April 14, 2023, states:

(...)

Regarding the number of users served by Electronic Banking and the modes of access:

(...)

Regarding the chronology of events. Actions taken to minimize adverse effects and measures adopted for final resolution.

In the Security Incident Analysis Report accompanying the breach notification form, it is noted:

(...)

From the areas of RSI responsible for fraud and the development of the NBE, the investigation begins to understand how the fraud occurred.

(...)

1. The mitigating measures carried out on December 7 and 9 were:

(...)

Regarding the causes that made the breach possible

(...)

Regarding the affected data

The information that may have been accessed during the breach includes personal, contact, and financial data:

(...)

In the Security Incident Analysis Report accompanying the breach notification form, the type of information extracted by the cybercriminal and the impact on individual clients is analyzed, taking into account, among others, the following variables:

(...)

During the course of the investigation proceedings, additional information was requested from RSI regarding (...) that the users compromised in the breach may have accessed. RSI, in its response document, states that:

(...)

Below are the personal and contact data:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/58

Regarding the data processing agreement

RSI provides the Record of Processing Activities of RSI and indicates that the processing related to the operation of Electronic Banking is the Customer Management processing, where RSI acts as the processor.

RSI provides the Agreement modifying the data protection clause of the service provision contracts signed between CAJA RURAL DE JAÉN, BARCELONA Y MADRID, S.C.C. (...).

RSI states that this Agreement was signed with the Entities in 2018 and that it is the same model for all of them.

The Agreement includes, among other aspects:

- The purpose of the Agreement is to establish the legal regime applicable to the processing of personal data that is processed or may be processed by the processor, under the service provision contracts signed between the parties, which are under the ownership and control of the data controller.
- The processor is obliged to process the data in accordance with the instructions of the data controller.
- The processor shall apply technical and organizational security measures to ensure an adequate level of security.
- The processor is authorized to subcontract the companies listed in Annex A of the Agreement – Subcontracting. The subcontractor, who also has the status of processor, is equally obliged to comply with the obligations established in the Agreement for the processor and the instructions issued by the controller.

Regarding security measures

RSI indicates that the planning for the development of the NBE extends from 2019 to 2022 and that during December 2019, a risk analysis of the NBE was conducted for both the Web version and the App. The following areas were analyzed:

(...)

From the Customer Management processing, RSI indicates that a data protection risk analysis has been conducted by the Data Protection Officer. This analysis is carried out with an initial review of the list of threats and the assessment of whether they apply to the processing or not, provides the threat assessment questionnaire, and a second part, where the risk analysis is conducted according to RSI's risk analysis methodology. The result of this analysis is provided.

RSI indicates that, (...) and that in compliance with this line of work, three security assessments have been conducted on Ruralvía Clásica, the reports of which are provided:

- Report prepared by the company ***EMPRESA.1, dated 28/02/2022.
- Report prepared by the company ***EMPRESA.1, dated 28/04/2022.
- Report prepared by the company ***EMPRESA.2, continuous evaluation reflecting the tests conducted between 01/10/2021 and 30/04/2023, where all critical vulnerabilities are closed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/58

The report prepared by the Cybersecurity department of RSI is also provided, which lists the (...) and the status of resolution of the detected vulnerabilities.

Additionally, RSI certifies that, (...) by an external provider. It attaches the audit report and states: [...]

Of the detected vulnerabilities, the one analyzed regarding the manipulation of the JWT Token (vulnerability 4.2.5 of the report) is similar to the attack pattern. However, in the case of the external audit conducted on the SSO specifically, as can be seen throughout the report, the auditors could not obtain customer data. This demonstrates that, despite the prior measures taken to ensure the proper functioning of the system and total protection of the final customers' data of the CCRR, this case in (...)

[...]

Regarding the manipulation (...), it was resolved in a new release deployed in production on July 18, 2022. Evidence is provided that certifies the resolution in the Production environment of this vulnerability.

RSI, in its submission dated October 1, 2023, explains:

(...)

It also lists the audits that have been conducted subsequent to those mentioned in previous information requests in compliance with the fraud plan:

(...)

Likewise, (...) to comply with the PSD2 Delegated Regulation, with the audited period from 15/12/2021 to 15/12/2022. The Report is dated 15/12/2022.

Specifically, it focused on reviewing the information associated with the security measures related to the enhanced authentication measures across the various channels and payment services offered by RSI. The Audit Report conducted by the firm ***EMPRESA.3 is provided.

To address the detected vulnerabilities in accordance with the level of compliance with PSD2 regulations, an action plan is implemented by RSI. The Action Plan with the current status is provided.

(...)

For this reason, the security measures implemented (...).

(...)

Technical and organizational measures adopted to prevent, as much as possible, incidents like the one that occurred.

In addition to the measures described above, RSI conveys that:

(...)

RSI, in its submission dated October 11, 2023, details the functioning of these controls:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/58

(...)

Throughout the month of February 2023, the following actions were carried out:

(...)

Regarding communication to the affected parties

9 entities, including CAJASIETE, have communicated the breach to all affected clients who have an Electronic Banking Agreement.

Another 10 entities of the Group have communicated the breach to all affected clients.

And another 7 have not communicated the breach to affected clients who are individuals:

The Model of communication to the affected parties by the breach is provided, which includes the contact details of the DPD (Data Protection Officer) of the Entity and describes the possible consequences of the incident for the affected parties.

Information on the recurrence of these events and the number of analogous events that have occurred over time

RSI states that these events are not recurrent, being this the first occasion on which they have occurred.

It also notes that they have not received any news from their service of (...) regarding the publication of data on the dark web.

THIRD: On 22/01/2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against CAJASIETE for the alleged infringements of Articles 5.1.f), 32.1, and 33.1 of the GDPR, classified under Articles 83.5.a) and 83.4.a) of the GDPR.

This initiation agreement, which was notified to CAJASIETE in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was recorded on 23/01/2024, as stated in the acknowledgment of receipt that is part of the file.

FOURTH: After the initiation agreement was notified, CAJASIETE requested, by means of a letter

dated 29/01/2023, a copy of the documents that made up the administrative file and an extension of the deadline to submit allegations and propose relevant evidence.

By letter dated 05/02/2024, the instructor extended the deadline for submitting allegations by a maximum of ten days, calculated from the day following the receipt of the copy of the file.

On 26/02/2023, the instructor of the file sent a written communication to the data processor indicating that "Since a large part of the documentation in the file has been provided by RSI through the General Electronic Registry, the registration numbers of the submitted documents were grouped by dates, so that within 10 working days, it could communicate whether there were documents, or parts of documents, that it considered should not be provided to the claimed party, due to reasons related to commercial secrecy, personal data protection, or others."

On 11/03/2024, the data processor stated that "regarding its transfer to the claimed party, my client considers that it does not correspond to it, but to the AEPD to assess the legality of such transfer and/or, if applicable, the existence of any impediments or limitations that may be established by the applicable regulations."

On 09/04/2024, the instructor of the procedure sent two writings to the claimed party: one, transferring the copy of the administrative file in accordance with the provisions of Article 53.1 a) of the LPCAP, and, independently, a second one in which the key and the hash were provided that would allow access to the documentation included in the physical support.

On 25/04/2024, CAJASIETE submitted a letter of allegations summarizing the following:

- That all procedures (26) opened against the entities belonging to the Caja Rural Group be accumulated due to the close connection and substantial identity; the absence of culpability of the claimed party in the present case;
- The impact on the principles of sanctioning law as a consequence of the interpretation made by the AEPD;
- Non-existence of a violation of Article 32.1 of the GDPR;
- Non-existence of a violation of Article 5.1.f) of the GDPR;
- Non-existence of a violation of Article 33 of the GDPR;
- Violation of the principle of proportionality in determining the sanctions;
- That the proceedings be archived or that a warning sanction or a significant reduction of the sanction be agreed upon.

FIFTH: On 21/10/2024, the opening of a period for the practice of evidence was agreed upon, with the following being agreed:

- To consider as reproduced for evidentiary purposes the complaint filed by the complainant and its documentation, the documents obtained and generated by the Inspection Services that are part of the file.
- To consider as reproduced for evidentiary purposes the allegations to the initiation agreement presented by the claimed party and the accompanying documentation.
- To request the claimed party to provide documentation proving that, if applicable, it had instructed its data processor to notify the AEPD of the personal data breach subject to this sanctioning file and the accreditation of both the aforementioned instruction and the terms contained therein, along with the date of the same.

On 05/11/2024, the claimed party responded to the evidence practiced, the content of which is part of the file.

SIXTH: Attached as an annex is a list of documents in the procedure.

From the actions carried out in the present procedure, the following have been accredited,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/58

PROVEN FACTS

FIRST:

As stated in the deed of elevation to public agreements regarding the granting of special power of

attorney granted by CAJASIETE CAJA RURAL, S.C.C., dated 27/03/2018, (...).

It is governed by the provisions of its Statutes and, in matters not provided for therein, by Law 13/1989, of May 26, on Credit Cooperatives, its development regulations, and other provisions that generally regulate the activity of credit entities, applying supplementary cooperative legislation. Likewise, as provided in its Statutes, it enjoys its own legal personality and full capacity to act.

SECOND:

On 24/04/2023, CAJASIETE submitted, along with the written allegations to the initiation agreement "Agreement to modify the data protection clause of the service provision contracts signed between CAJASIETE and RSI dated 18/09/2018 and signed on behalf of CAJASIETE by Mr. A.A.A.

In said Agreement, it is specified:

"ON THE ONE HAND, CAJASIETE (hereinafter, Data Controller), with C.I.F (...), with address at (...), 38003 SANTA CRUZ DE TENERIFE, and represented in the signing of this Contract by Mr. A.A.A., with D.N.I ***NIF.1

AND

ON THE OTHER HAND, RSI (hereinafter, Data Processor), with C.I.F (...), with address at (...) 28760 Tres Cantos (Madrid), and represented in the signing of this Contract by Mr. B.B.B. with D.N.I ***NIF.1"

In said agreement, it is indicated that,

"The purpose of the Agreement is to establish the legal regime applicable to the processing of personal data that is processed or may be processed by the data processor, by virtue of the service provision contracts that are signed between the parties, and that are under the ownership and control of the data controller.

The data processing foreseen is that which is strictly necessary for the provision of the services provided in the main contract. The processing that could be carried out by RSI, the type of information to be processed, and the categories of data subjects whose data could be processed are defined."

In the Agreement itself, it is indicated, in its section 3, regarding the Obligations of the Data Processor, that:

"The Data Processor and all its personnel are obliged to:

a) Use the personal data subject to processing, or those collected for its inclusion, only for the purpose of this assignment. Under no circumstances may the data be used for any other purpose, whether for its own or for third parties. To carry out any other activity aimed at the processing or use of the data files of the Data Controller, prior written consent from the latter will be necessary.

b) Process the data in accordance with the instructions of the Data Controller.

(...)"

Regarding the notification of "data security breaches," it is specified in section 3.3 that:

"The Data Processor shall notify the Data Controller, without undue delay, and in any case, before the maximum period of 36 hours, and through the DPO, of any breaches of the security of personal data under its charge of which it becomes aware, along with all relevant obligations for the documentation and communication of the incident.

(...)."

Section 3.4 regarding security measures adds that:

"The Data Processor, in accordance with the provisions of Article 32, shall apply those technical and organizational measures appropriate to ensure a level of security adequate to the risk of processing detected in each case, considering the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks for the rights of individuals at any given time.

In any case, it must implement mechanisms equivalent to those used by the Data Controller to:

a. Ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services.

b. Restore the availability and access to personal data quickly in the event of a physical or technical incident.

c. Regularly verify, evaluate, and assess the effectiveness of the technical and organizational measures implemented to ensure the security of processing.

d. Pseudonymize and encrypt personal data, where applicable.

The technical and organizational measures to be implemented by the processor are reflected in Annex B of this agreement - Security Measures.

The processor is authorized to subcontract the companies reflected in Annex A of the Agreement - Subcontracting. The subcontractor, who also has the status of data processor, is equally obliged to comply with the obligations established in the Agreement for the data processor and the instructions issued by the controller.

Regarding the obligations of the data controller, it is indicated in section 4 of the Agreement:

"It is the responsibility of the data controller:

a) To provide the Data Processor with the necessary data for the provision of the service.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/58

b) In the event that it is legally required, conduct an impact assessment on the protection of personal data for the processing operations to be carried out by the Data Processor.

c) Carry out the necessary prior consultations.

d) Ensure, both prior to and throughout the processing, compliance with the GDPR by the Data Processor.

e) Supervise the processing, including conducting inspections and audits."

In section 5, the DPO of the processor and the controller of the processing are identified respectively.

Regarding CAJASIEDE, the DPO is listed as:

"Identification (...)

Contact ***EMAIL.1

Regarding RSI, the DPO is listed as:

"Identification Ms. C.C.C

Contact ***EMAIL.1

Section 6 of the Agreement on "Liability" states that,

"If the Processor, or in its case, the contractors, breach this Agreement or the applicable regulations by determining the purposes and means of processing, they will be considered responsible for the processing concerning that processing.

In the event that a supervisory authority sanctions the Data Controller as a direct consequence of the Data Processor's failure to comply with the stipulations of this Agreement, the Processor shall indemnify the Data Controller as stipulated in the liability clause of the framework contract in force between the parties."

THIRD:

In the "Agreement to amend the data protection clause of the service provision contracts," signed between CAJASIEDE and RSI, signed in Madrid on 18/09/2018, Annex B - Security Measures to the Agreement to amend the data protection clause of the service provision contracts indicates that RSI has the following certifications:

(...)

Furthermore, in the "Agreement to amend the data protection clause of the service provision contracts," it is indicated that RSI has the following measures:

(...)

FOURTH:

On 13/12/2022, a personal data breach of CAJASIEDE was reported to the Division of Technological Innovation of this Agency, with entry number REGAGE(...). This notification was sent by RSI, the data processor of CAJASIEDE. Attached to this notification is the "Security Incident Analysis Report."

On 10/01/2023, a personal data breach was reported to the Division of Technological Innovation of this Agency, with entry number REGAGE(...). This notification was sent by RSI, the data processor of CAJASIEDE. Attached to this notification is the "Final Security Incident Analysis Report."

FIFTH:

CAJASIEDE had the electronic banking application called Ruralvía Clásica for the purpose of providing

online banking services to its clients.

CAJASIETE wanted to change this application to a new electronic banking application called Nueva Banca Electrónica (NBE).

(...)

On 14/04/2023, in response to the request made by the AEPD, RSI states that:

"(...)"

SIXTH:

Regarding the establishment of a banner in the Ruralvía Clásica application that linked to the new NBE application and its operation, in the "Security Incident Analysis Report," dated December 9, 2022, which RSI provided concerning the personal data breach of CAJASIETE, it is indicated:

"(...)"

Additionally, on 14/04/2023, in response to the request made by the AEPD in the context of the preliminary investigation proceedings, RSI responded that:

"(...)"

SEVENTH:

(...)

On 14/04/2023, in response to the request made by the AEPD in the context of the preliminary investigation proceedings, a document 9 titled "Web Application Audit" was submitted, indicating that each user and for each open user session a token is generated that identifies and individualizes them:

(...)

EIGHTH:

(...)

NINTH:

Regarding how the personal data breach occurred, on 14/04/2023, RURALVÍA, in response to the information request made by this Agency, states the following,

"(...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/58

Furthermore, in the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASIETE, it is stated in section 1.4.2, "How was the problem detected or how did it happen?", that:

"(...)"

TENTH:

Additionally, in the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASIETE, in section 1.4.1, "What happened?", it is indicated that the personal data breach occurred due to a vulnerability in the SSO system, stating that:

(...)

ELEVENTH:

Regarding the attack pattern used by the cybercriminal, on 14/04/2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, RSI indicates that,

(...)

The same provision is contained in section 1.4.2 of the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASIETE.

TWELFTH: Regarding the causes that allowed the personal data breach, in the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASIETE, it is stated in section 3, "Cause Analysis," that:

(...)

THIRTEENTH:

In response to the information request made by the AEPD within the framework of the preliminary

investigation proceedings, RSI responded on 26/05/2023, providing as document 8 an email dated 28/09/2022, prior to the occurrence of the higher volume of accesses (between November 10 and 23 of the same month) and the detection of the personal data breach, sent by (...).

(...).

In the same vein, as indicated, on 14/04/2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, RSI responded that,

"(...)"

On April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, document 9 titled "Web Application Audit" was submitted, indicating that,

"(...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/58

FOURTEENTH:

On 14/04/2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, document 9 titled "Web Application Audit" was submitted, in which

***TOOL.1 was examined.

FIFTEENTH:

Regarding the detection of the personal data breach, in the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASIEETE, it is stated in section 1.4.1, "What happened?", that:

(...)

Therefore, although the breach was detected on December 7, 2022, prior accesses to that date are confirmed, noting that the highest volume of accesses occurred between November 10 and November 23, 2022.

Regarding the measures adopted on November 23, 2022, the aforementioned document indicates that,

(...)

Therefore, these measures were adopted before the detection of the personal data breach (on December 7, 2022) and as a result of actions to increase the security of online banking.

SIXTEENTH:

Regarding the mitigating measures applied after the personal data breach, in the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASIEETE, it states that,

"(...)"

SEVENTEENTH:

Subsequently, within the framework of the definitive implementation of the new NBE application, a series of actions were carried out, as noted in the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASIEETE, that,

(...)

EIGHTEENTH:

Regarding the personal data accessed by the attacker, in the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASIEETE, it indicates which personal data may have been accessed,

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/58

NINETEENTH:

The notification forms of the breach, which are accompanied by the Security Incident Report prepared in all cases by RSI, the data processor, as stated in the preliminary investigation report dated November 27, 2023, determine that the number of individuals affected by the personal data breach of CAJASIETE is 3,708 users.

TWENTIETH:

During the testing period referred to in the Fifth Background, CAJASIETE provided the following documents regarding the notification of the personal data breach to the AEPD:

- Email dated 12/13/2022, sent by RSI to CAJASIETE, in its capacity as data processor, informing about the security incident, indicating that they were preparing a report on it and the steps to be taken (notification to the AEPD and communication to the affected parties) and requesting validation from CAJASIETE as the data controller. It states:

“(…)

After conducting the corresponding triage, the incident requires communication to the AEPD and the affected clients, so we have a margin of 72 hours from its notification to communicate it to the control authority.

In this regard, we can submit the notification to the AEPD as data processors, on behalf of the Entity. For this, we kindly need your consent as a response to this email.”

(…)”

- Responsibility statement dated 11/04/2024 from the Operations Manager of CAJASIETE, in which it states that,

“On December 12, 2022, RURAL SERVICIOS INFORMÁTICOS S.L. (RSI), in its capacity as data processor for this entity, communicated to it the report on the security breach that occurred in its systems, requesting instructions regarding the notification of the incident, both to the Spanish Agency for Data Protection and to the affected parties, in accordance with the provisions of Articles 33 and 34 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, concerning the protection of natural persons with regard to the processing of personal data and the free movement of such data. In particular, instructions were requested from this entity regarding the possibility of notifying the security breach to the aforementioned Agency by RSI, as the data processor for CAJASIETE.

Given the urgency of this situation, on the same date that the aforementioned email was received, verbal instructions were given by this entity to RSI, so that it could proceed immediately with the notification of the security breach to the Spanish Agency for Data Protection, acting in any case on behalf of and for the account of CAJASIETE.”

- Email dated 12/12/2022, sent by RSI to CAJASIETE, in which it communicates that the security breach had been notified to the AEPD, in response to the instructions given by its representative. It states:

“(…)

Attached you will find the proof of notification of the incident to the AEPD for your knowledge and filing.”

(…)”

TWENTY-FIRST:

According to the diligence dated 01/19/2024 in the file, the business volume (gross margin) of CAJASIETE during the fiscal year 2022 amounts to 74,280,000 euros.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and

guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In the case examined, in accordance with the provisions of Article 4.1 of the GDPR, it is established that personal data processing is taking place, as CAJASIETE collects and retains personal data from both natural and legal persons, its clients, such as: (...).

The entity carries out this activity in its capacity as data controller, as it is the one that determines the purposes and means related to the processing of personal data.

16/58

Processing of personal data, pursuant to Article 4.7 of the GDPR. Therefore, if you decide the "why" and the "how" personal data should be processed, you must assume your responsibility.

Furthermore, the data controller must also be responsible for implementing the technical and organizational measures that ensure the security of personal data when carrying out the processing. And must be able to demonstrate compliance with the GDPR and the LOPDGDD.

In turn, Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

In this case, there is a security incident categorized as a personal data breach, having occurred unauthorized access to personal data.

It should be noted that the identification of a personal data breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the controllers and processors and the security measures applied.

Among the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in paragraph 1.f).

In turn, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of processing, notification to the supervisory authority, and communication to the data subject, respectively.

As previously mentioned, it is presumed that the data controller is the entity that has the true capacity to exercise control over the data, who determines the why and how the data should be processed.

On the other hand, according to the diligence dated 19/01/2024 in the file, the turnover (gross margin) of CAJASIETE during the fiscal year 2022 amounts to 74,280,000 euros.

III

Description of the personal data breach

CAJASIETE had the electronic banking application called Ruralvía Clásica for the purpose of providing online banking services to its customers.

For a customer to enter the Ruralvía Clásica application and log in, they needed to enter their identifier, password, and NIF.

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/58

IV

Unfulfilled obligation: violation of Article 5.1.f) of the GDPR.

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in such a way as to ensure an adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

(...)

Thus, as stated in the proven fact nineteenth, regarding the personal data to which the attacker had access, the "Final Incident Analysis Report," dated 30/12/2022, indicates that,

(...)

Although the personal data breach was detected on 07/12/2022, prior accesses to that date are confirmed, with the highest volume of accesses occurring between 10 November and 23/11/2022. In this regard, in the aforementioned report of 30/12/2022, as stated in the proven fact eighth and fourteenth, it is indicated in section 1.4.2, "How was the problem detected or how did it happen?", that:

(...)

The attacker was able to access those personal data of CAJASIETE's customers due to the lack of appropriate technical and organizational measures prior to the occurrence of the personal data breach. First, it should be noted that, as stated in the proven fact eleventh, regarding the causes that allowed the personal data breach, in the "Final Incident Analysis Report," dated 30/12/2022, in section 3, "Cause Analysis," that:

(...)

Secondly, in the proven fact fifteenth, the mitigating measures implemented are recorded, which highlight the absence of appropriate technical and organizational measures to prevent the occurrence of the breach, emphasizing, for such purposes,

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/58

In conclusion, and in accordance with all that has been indicated, it has been established that the violation of the principle of confidentiality did indeed occur, as the attacker accessed multiple personal data of clients of CAJASIETE. This was made possible due to the lack of appropriate technical and organizational measures highlighted by the aforementioned vulnerabilities. The number of clients of the entity affected by the breach is (...). All of them were notified of the security incident that occurred.

The documentation in the file provides clear evidence that CAJASIETE violated Article 5.1(f) of the GDPR, "Principles relating to processing," by failing to adequately ensure the confidentiality and integrity of personal data as a result of the personal data breach that occurred. Furthermore, CAJASIETE confirms the external origin of the security breach, thus confirming access by unauthorized third parties. Although the entity does not know how long this data has been exposed, it does detail the dates on which the security incident occurred: "...it is estimated that the incident occurred from September until November 23, 2022."

In accordance with the evidence available in this proposal for the resolution of the sanctioning procedure, it is considered that the known facts could constitute an infringement attributable to CAJASIETE for violating Article 5.1(f) of the GDPR.

V

Classification for the infringement of Article 5.1(f) of the GDPR

In accordance with the evidence available and without prejudice to what results from the instruction, it is considered that CAJASIETE did not adequately guarantee the confidentiality and integrity of personal data. The infringement attributed to the entity is classified under Article 83.5(a) of the GDPR, which states that the infringement of "the basic principles for processing, including the conditions for

consent under Articles 5, 6, 7, and 9" is subject to penalties, according to paragraph 5 of the aforementioned Article 83 of the Regulation, "with administrative fines of up to €20,000,000 or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount."

The LOPDGDD in its Article 71, Infringements, states that: "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements." And in its Article 72, it considers for the purposes of prescription that they are: "Infringements considered very serious:

1. According to what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that imply a substantial violation of the articles mentioned therein are considered very serious and will prescribe in three years, particularly the following:

(...)

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.

(...)"

VI

Proposal for sanction for the infringement of Article 5.1(f) of the GDPR

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding to impose an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and detriment they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and detriment suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have applied in accordance with Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular, whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/58

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.

In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, "Sanctions and corrective measures," establishes that:

"2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The ongoing nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party."

According to the transcribed provisions, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the GDPR for which CAJASIETE is held responsible, the following factors are considered concurrent:

- The nature, severity, and duration of the infringement; the facts revealed affect a basic principle related to the processing of personal data, such as confidentiality and integrity, which the regulation penalizes with the utmost severity as it allows, as a consequence of the personal data breach, access to personal data by unauthorized third parties with the potential harm this may entail.
- The number of affected parties: (...).

Regarding the level of damages caused: it should be considered high since (...) as users who had an Electronic Banking agreement would have been able to access this type of data (account number(s) and balance(s)).

Additionally, it should be noted that this situation enables access to the data, which can lead to the materialization of the risk of identity theft, among others (Article 83.2.a) of the GDPR).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/58

- The intentionality or negligence in the infringement. There is a lack of diligence in complying with the obligations imposed by data protection regulations, allowing access by cybercriminals to personal data, thereby violating its confidentiality; in this regard, the SAN of 17/10/2007 can be cited, which, although issued before the GDPR came into force, is perfectly extrapolable to the case we are analyzing. The judgment, after referring to the fact that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, specified that "(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard" (Article 83.2.b) of the GDPR).
- The activity of the allegedly infringing entity is linked to the processing of personal data of both customers and third parties. In the activity of the claimed entity, the processing of personal data is essential, so given its object and business volume, the significance of the conduct subject to this claim is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

For the purpose of deciding on the proposal for the fine and its amount, in accordance with the available evidence, taking into account the criteria of Article 83.2 of the GDPR regarding the

infringement committed, violation of Article 5.1.f) of the GDPR, it is considered appropriate to propose a sanction of 250,000 euros.

VII

Infringement of Article 32.1 of the GDPR.

Article 32 of the GDPR "Security of processing" establishes that:

"1. Taking into account the state of the art, the costs of application, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/58

- d) a process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of the processing.

2. In assessing the adequacy of the security level, particular consideration shall be given to the risks presented by the data processing, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union or Member State law.

Having reviewed the allegations made by CAJASIETE, and in consideration of the same, having reviewed the documentation in the administrative file and that provided by the responding party, it is evident that all the technical and organizational security measures whose absence has been proven, directly enabling the personal data breach, have not resulted in a violation, in this specific case, of Article 32 of the GDPR as the absence of other independent technical and organizational security measures unrelated to the personal data breach has not been established.

VIII

Violation of Article 33.1 of the GDPR

Article 33 of the GDPR, "Notification of a personal data breach to the supervisory authority," establishes that,

"1. In the case of a personal data breach, the controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, not later than 72 hours after becoming aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by reasons for the delay.

2. The processor shall notify the controller without undue delay of any personal data breaches of which it becomes aware.

3. The notification referred to in paragraph 1 shall, at a minimum:

- a) describe the nature of the personal data breach, including, where possible, the categories and

approximate number of data subjects affected, and the categories and approximate number of personal data records affected;

b) communicate the name and contact details of the data protection officer or another contact point where more information can be obtained;

c) describe the likely consequences of the personal data breach;

d) describe the measures taken or proposed by the controller to remedy the personal data breach, including, where appropriate, the measures taken to mitigate its possible adverse effects.

4. If it is not possible to provide the information simultaneously, and to the extent that it is not possible, the information shall be provided in phases without undue delay.

5. The controller shall document any personal data breaches, including the facts relating to the breach, its effects, and the remedial measures taken. This documentation shall enable the supervisory authority to verify compliance with the provisions of this article."

On 21/10/2024, it was agreed to open a period for the practice of evidence, in which point 3 stated that it was agreed to require CAJASIETE:

"To provide documentation proving that, where applicable, it had instructed or given instructions to its processor for the notification to the AEPD of the personal data breach subject to this sanctioning file. Proof of both the aforementioned instruction and the terms contained therein and the expression of the date thereof."

The investigated party has provided in response to this requirement on 05/11/2024, the following documents:

- Email dated 13/12/2022, sent by RSI to CAJASIETE, in its capacity as processor, in which it communicates the security incident, indicating that they were preparing a report on it and the steps to be taken (notification to the AEPD and communication to the affected parties) and requesting validation by CAJASIETE as the controller. Thus, it communicates that:

"(...)

After conducting the corresponding triage, the incident requires communication to the AEPD and the affected clients, so we have a margin of 72 hours from its notification to communicate it to the supervisory authority.

In this regard, we can submit the notification to the AEPD as processors on behalf of the Entity. For this, we need, please, your consent as a response to this email."

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/58

- Responsibility statement dated 04/11/2024 from the Operations Manager of CAJASIETE, in which it is stated that,

"On December 12, 2022, RURAL SERVICIOS INFORMÁTICOS S.L. (RSI), in its capacity as data processor for this entity, communicated to the same the report on the security breach that occurred in its systems, requesting instructions regarding the notification of the incident, both to the Spanish Data Protection Agency and to the affected parties, in accordance with the provisions of Articles 33 and 34 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data. In particular, instructions were requested from this entity regarding the possibility of notifying the security breach to the aforementioned Agency by RSI, as the data processor for CAJASIETE.

Given the urgency of this situation, on the same date that the aforementioned email was received, this entity verbally instructed RSI to proceed immediately with the notification of the security breach to the Spanish Data Protection Agency, acting in any case on behalf of and for the account of CAJASIETE."

- Email dated 12/12/2022, sent by RSI to CAJASIETE, in which it communicates that it had proceeded to notify the security breach to the AEPD, in response to the instructions given by its represented party.

Thus, it communicates that:

“(…)

Attached you will find the proof of notification of the incident to the AEPD for your knowledge and filing.”

(…)

After analyzing the documentation presented by CAJASIETE referred to in the twentieth proven fact, it is determined that RSI (responsibility statement in a private document by the highest responsible person of the entity, based on the request for prior instructions from the data processor and the immediate subsequent action of notifying the personal data breach to the AEPD) has provided in response to the evidence gathering carried out by this Agency on 21/10/2024 regarding the accreditation of the instructions provided to its data processor, so that it could proceed with the notification on its behalf to the AEPD of the personal data breach subject to the aforementioned procedure, in accordance with Article 33 of the GDPR.

Therefore, it must be concluded that, after analyzing the investigated facts, the allegations made by the responding party, and the evidence provided in the procedure, considering the circumstances present in the specific case, the filing of the alleged infringement in relation to Article 33.1 of the GDPR would be appropriate.

IX

Response to the allegations made regarding the initiation agreement

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/58

In relation to the allegations made by CAJASIETE regarding the initiation agreement, a response is provided to them in the order in which they are presented in their writing:

FIRST. ON THE ACCUMULATION OF THE PROCEDURES TO THE GROUP ENTITIES.

1. Preliminary considerations

According to CAJASIETE: “All the initiation agreements in the files that have just been referenced arise, as indicated, from the security breach analyzed by the Initiation Agreement” and subsequently states that “we are faced with a single fact, referring to a single breach, suffered during the development of the aforementioned tool carried out by RSI in its capacity as data processor and which, however, is fragmented by the AEPD into twenty-six differentiated procedures processed against twenty-six different entities.”

In response to these preliminary considerations, it should be noted that the responding party confuses the factors that determined the vulnerability being similar in all the procedures initiated by this Agency with the fact that only a single personal data breach has occurred.

We are dealing with incidents that have affected (…) which are completely independent, both legally and economically. Each of these entities is responsible for the data processing of its clients in a differentiated manner, and consequently, there are as many personal data security breaches as there are data controllers who have failed to comply with the obligations imposed by the GDPR. Each entity is responsible for the processing of its own data and regarding its own clients.

All the entities referred to by the responding party in their allegations had contracted with RSI, (...).

However, the fact that RSI was the same data processor for all the Entities does not determine that one can speak of “a single fact, referring to a single breach.”

Each entity, as the data controller of its clients, autonomously made the decision to contract with RSI as the data processor, for which each of them signed their own data processing agreement, on different dates, signed by different persons with sufficient authority for this in each of the rural banks and citing their different data protection delegates, who are not the same.

Furthermore, as also stated in the proven facts, both the “Incident Analysis Report,” dated 09/12/2022, and the “Final Incident Analysis Report,” dated 30/12/2022, were carried out individually for each of the rural banks, containing their own specificities.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
26/58

Likewise, once the breach of personal data has occurred, the actions of each of the entities have not been the same, with each acting autonomously, both in relation to the AEPD (some entities have notified the personal data breach directly while others have entrusted their data processor to carry it out), as well as concerning their respective clients and independently of the actions of others.

2. Regarding the accumulation of administrative procedure files.

In this allegation, the responding party considers that: "The legal regime for the accumulation of procedures, as well as processes, in the administrative sphere responds to the central idea of connectivity, that is, that the instruction work that must be carried out is favored by the overall appreciation of the issue raised and the possibility that the joint viewing work allows for a better assessment of the elements that enable the application of the norm to the specific case."

Article 57 of the LPACAP on the accumulation of procedures establishes that: "The administrative body that initiates or processes a procedure, regardless of how it was initiated, may, ex officio or at the request of a party, order its accumulation to others with which it has substantial identity or intimate connection, provided that it is the same body that must process and resolve the procedure. No appeal shall proceed against the accumulation agreement" (the underlining corresponds to the AEPD).

Consequently, both the administrative body that initiates the procedure and the one that processes it may order its accumulation to other procedures with which it has substantial identity or intimate connection, provided that it is the same body that must process and resolve the procedure.

Article 57 of the LPACAP grants administrative bodies the authority for better management of the procedures they process, allowing for their accumulation as long as there is substantial identity or intimate connection among them. Therefore, it is a possibility available to the Administration, which is not obliged to proceed with the accumulation if requested, although it must decide on the matter with justification, as occurs in the present sanctioning procedure.

3. Regarding the response to the allegation seeking the accumulation of sanctioning procedures.

In this allegation, the responding party considers that: "The legal regime for the accumulation of procedures, as well as processes, in the administrative sphere responds to the central idea of connectivity, that is, that the instruction work that must be carried out is favored by the overall appreciation of the issue raised and the possibility that the joint viewing work allows for a better assessment of the elements that enable the application of the norm to the specific case."

It should be noted that the claims of the responding party are not supported by either Article 57 of the LPACAP or by any type of jurisprudence.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
27/58

or doctrine, in which the purpose of accumulation is attributed to providing the decision-making body with a better assessment of the elements of the case.

The institution of accumulation is a technique of administrative simplification that allows the competent body to process and resolve a main procedure, the possibility of accumulating it with others that have substantial identity or intimate connection, for the purposes of simultaneous processing and resolution. The instrumental nature of accumulation is determined by the first limit established by Article 57 of the LPACAP, which states that the body "must be the same body that processes and resolves the procedure."

It is an administrative act that cannot be appealed, as established by Article 57 of the LPACAP itself, unlike what is provided in Article 112.1 of the same regulation, which does allow for the challenge of other administrative acts when they "directly or indirectly decide the merits of the matter, determine the

impossibility of continuing the procedure, produce defenselessness or irreparable harm to legitimate rights and interests."

However, when the LPACAP excludes the possibility of appeal, it is because it applies to the accumulation of procedures, as an administrative act, none of the cases in Article 112.1 of the LPACAP that we have just reproduced.

With these arguments as a starting point, the allegations made by the responding party that follow must be completely dismissed, to which a specific response will also be provided.

A) Existence of "intimate connection" or "substantial identity."

The responding party reiterates the idea referred to in the preliminary considerations of this FIRST allegation, stating that "a single breach of personal data security occurred, notified by each of the responsible parties (directly or through their data processor RSI)." It continues to assert that "the connectivity, in this case, derives from the fact that it is about determining responsibility for twenty-six legal entities, but for the same fact."

As already substantiated in the response to the preliminary considerations of this FIRST allegation, it cannot be said that there was a single breach of personal data security, but rather that as many breaches of personal data security occurred as there are entities, all of which are independent of each other, each responsible for its own processing and regarding its own clients, whose systems have suffered a security breach.

For the responding party, there is a single fact upon which responsibilities can be demanded, the security incident in the field of information technology. However, beyond the breach of personal data itself, there has been a loss of confidentiality of the personal data of the clients of each of the entities, which cannot be encompassed as a single fact or as the same fact.

In the same way, the facts related to the actions following the knowledge of the security breach by each of the entities must be differentiated.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/58

Some entities notified the AEPD directly about the breach, while in other cases, the communication was made by the data processor on behalf of each of the data controllers (in different ways and at different times). Lastly, some entities communicated the loss of confidentiality of their personal data to the affected individuals, fulfilling the obligation established in Article 34 of the GDPR, while other entities did not send any type of communication. All these various factual elements determine that it cannot be said that, beyond the same cybersecurity vulnerability, there exists an "intimate connection" or "substantial identity" that justifies the accumulation of the proceedings.

Regarding the ruling of the TSJ Castilla-La Mancha cited in the allegations, the following clarifications should be made:

1) There is no compliance with an obligation by several persons jointly, so the assumption of Article 28.3 of Law 40/15 does not apply. According to Article 28.3 of Law 40/2015, of October 1: "When the compliance with an obligation established by a norm with the rank of Law corresponds to several persons jointly, they will be jointly liable for the infringements that may be committed and for the sanctions that are imposed. However, when the sanction is monetary and it is possible, it will be individualized in the resolution based on the degree of participation of each responsible party."

In the present case, it cannot be said that there is a joint liability, as it does not concern a joint obligation of CAJASIETE with the other entities referred to in its written allegations. The facts constituting the infringement attributed to CAJASIETE are in its capacity as data controller, in accordance with the provisions of Article 4 of the GDPR, so the compliance with the principles and obligations established in the GDPR regarding the data processing of its clients corresponds to it individually, not jointly with the other entities, since, moreover, there is no joint liability in the GDPR. It should be noted that the fine imposed on each entity depends on its own circumstances, such as the number of affected clients or its business volume.

The figure of joint data controllers regulated in Article 26 of the GDPR would also not be applicable in

this case, “when two or more controllers jointly determine the purposes and means of processing, they will be considered joint controllers.” The purposes and means of processing have been determined by CAJASIETE independently of the other entities, in its capacity as the sole data controller of the personal data of its clients.

Finally, the assumption described in the ruling does not apply to CAJASIETE in relation to the other entities, in which “the Administration imputes different forms of cooperation or collusion among the three defendants.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
29/58

in relation to the same facts.” Here, there can be no talk of any type of cooperation or collusion in the facts, simply the responsibility of each of the Rural Banks, and their relationship with the data processor, due to the regime established in the GDPR.

2) The separate processing of the files does not prevent each entity from presenting its allegations. In the ruling of the TSJ of Castilla La Mancha referred to by CAJASIETE, in the Third Legal Ground, it is stated that the plaintiff requested that all procedures be consolidated in order to adequately exercise the right of defense, “...as they referred to the same facts, and it was expressly warned that processing them separately would constitute a serious violation of the right of defense as it would prevent knowledge of the allegations of the other parties involved and the documents they might submit, all of which could have implications for the legal qualification of the facts, the determination of the existence or not of an infringement, and the responsible party for it.”

The non-consolidation of procedures cannot produce any of the harms mentioned in that paragraph of the ruling.

Regarding the documents submitted to the procedure, those referring to the security incident, a series of documents were submitted by the data processor during the investigative proceedings (let us remember that both the “Security Incident Analysis Report,” dated 09/12/2022, and the “Final Security Incident Analysis Report,” dated 30/12/2022, were prepared individually for each of the rural banks, containing their specificities), whose access to all affected entities has been guaranteed through the sending, upon request, of a copy of the file. Those documents submitted by the entities responsible for processing, which affect them individually, will be taken into consideration in the corresponding procedure.

3) CAJASIETE reiterates the need for the “accumulated analysis of the files,” when the ruling of the TSJ of Castilla La Mancha does not include this idea.

The need for accumulation is based on considerations other than those expressed by CAJASIETE. As we have analyzed:

- Reference is made to access to the documents in the file that may be submitted by different responsible parties, a matter that we see is guaranteed here.
- The possibility of establishing joint liability is mentioned, which, as we have substantiated, does not apply under the regime established in the GDPR. We must not confuse the joint liability of Article 28 of the LRJSP with the co-responsibility of Article 26 of the GDPR, which also does not apply in this case, since, as we stated, in no case are the other Rural Banks co-responsible for the processing of customer data of the other entities.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/58

- There is no type of cooperation or collusion among the different Rural Savings Banks in the facts. These figures must be dismissed due to the relationship between the Rural Savings Banks, which are independent entities, each responsible for the treatment of their clients, nor, as we have previously stated, regarding the special regime established by the GDPR concerning the relationship between the

data controller and the data processor.

B) That the same body is responsible for the processing and resolution of the procedure.

The processing of the various sanctioning procedures corresponds to the same body, as stated by CAJASIETE, which does not determine the mandatory nature of the decision to consolidate the procedures, especially when there are no circumstances that imply the defenselessness of CAJASIETE.

4. Connectivity in the sanctioning field

In this allegation, CAJASIETE points out that the Constitutional Court has declared that both the substantive principles of Article 25.1 of the Spanish Constitution (CE) and the procedural guarantees of Article 24.2 CE are applicable, with certain nuances, to the exercise of sanctioning power.

4.1. General aspects related to the instruction and its essential functionality.

A) Linkage of the instruction as a consequence of the factual unity.

CAJASIETE cites a ruling from the Supreme Court, which states that “the initiation of a single sanctioning procedure for the commission of the same infringing act, with the aim of determining the degree of participation of each alleged responsible party in the commission of the infringement and ensuring that the resolution of the file is coherent...” According to CAJASIETE, “In this case, the appellant argued that, since two files were processed, each of the responsible parties was unaware of what was in the other that could benefit or harm them. This is a concrete example of the difficulties that arise in terms of the right to defense in cases of separate processing.”

As previously justified, there are as many breaches of personal data as there are data controllers, and we cannot speak of a single infringing act, but rather of a series of infringing acts attributable to a series of independent entities concerning the treatments for which they are responsible, regarding their clients; nor can we speak of “degree of participation” among the various entities, nor in terms of the relationship between the data controller and the data processor.

Regarding the documents submitted to the procedure, those related to the security incident, a series of documents were provided by the data processor during the investigation proceedings, whose access to all affected entities has been guaranteed through the prior request for a copy.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/58

of the file. And all of this in addition to the fact that RSI submitted the “Security Incident Analysis Report,” dated December 9, 2022, as well as the “Final Security Incident Analysis Report,” dated December 30, 2022, in a detailed manner for each of the rural banks, containing their specificities. Those documents submitted by the entities responsible for the processing, which affect them individually, will be taken into consideration in the corresponding procedure. And those others that may constitute evidence relevant to the facts will be duly incorporated into the other files ex officio, in accordance with the provisions of Article 75 of the LPACAP, “the necessary instructional acts for the determination, knowledge, and verification of the facts on which the resolution must be pronounced shall be carried out ex officio.”

Regarding the right to defense

B) Connectivity as a fundamental prerequisite for the exercise of the right to defense.

According to CAJASIETE, the breach of the continuity of the case, in this instance, of the sanctioning administrative procedure implies that the two procedures become “sealed” and that the evidence, allegations, and expert opinions conducted in one cannot be presented contradictorily in the other. However, a paragraph from the judgment transcribed by CAJASIETE is fully applicable to respond to the present allegation: “it is not specified to what extent their defense had been ‘prejudiced’,” and to reject it, just as the Supreme Court understands “that the decision of the lower court is correct, which considers that the initiation of sanctioning files against each of the companies is justified... due to the clear differentiation of the behaviors attributed and it has not been demonstrated that there was real defenselessness - as reasoned in the contested judgment.”

The Constitutional Court in its judgment No. 210/1999, of November 29, indicates that the constitutionally relevant defenselessness is the situation in which, after the infringement of a procedural norm, one of the parties is prevented from exercising the right to defense by eliminating or limiting their power, either to assert rights and interests to have them recognized, or to dialectically respond to opposing positions in the exercise of the principle of contracting.

As an essential characteristic of defenselessness, it must be material and not merely formal, that is, it is not sufficient to have a defect or procedural infringement; there must have been an effective and real right to defense (judgment of the Constitutional Court No. 90/1988, of May 13).

Well then, beyond a generic allegation of the potential defenselessness that could arise from the non-accumulation of the procedures, CAJASIETE is unable to present a single defect or procedural infringement that has limited its right to defense.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/58

the defense effectively, when the allegations presented by the affected Rural Banks regarding the security incident are substantially similar, and they have had access to all the documentation that affects them in a common manner. In any case, the instructing body will incorporate into the procedure and inform CAJASIETE of any other documents that may constitute evidence relevant to the facts.

4.2.- The intimate connection as a requirement for the individualization of responsibility for the same facts.

CAJASIETE argues that, since we are dealing with a single personal data breach, processing separate procedures for each of the responsible entities may eventually lead to the determination of diverse responsibilities. The intimate connection translates into the principle of uniqueness in determining the concurrence of the facts when, as CAJASIETE claims, it concerns unique facts that result in a single personal data breach.

As previously motivated, it cannot be said that there is a single personal data breach, but rather as many as there are data controllers who have suffered the security incident concerning their clients' data.

There cannot be different degrees of responsibility between CAJASIETE and the other entities. Each of the data controllers will have a degree of responsibility that must be determined individually regarding compliance with data protection regulations, without any type of cooperation in the commission of the infringement among the different Rural Banks that could determine different degrees of responsibility among the entities, as CAJASIETE claims.

CAJASIETE continues its reasoning by stating that "responsibility cannot be individualized without first objectifying the sanctioning reproach and this cannot be projected in 26 procedures with their own dynamics, their own evidence...". Abstract arguments are still being made, such as objectifying the sanctioning reproach, regarding its own dynamics and "its own evidence," when there have not even been allegations questioning the evidence of the facts, nor has a request for the reception of evidence in the procedure been made.

The fact that "a single investigation procedure" has been processed and that no requirement has been directed against the responsible entities for the processing but rather in relation to the processor (RSI) does not imply the "unitary factual determination," as CAJASIETE argues. That the inspection actions were directed to require information from the processor does not determine that subsequently a single procedure must be initiated to clarify administrative responsibilities. It should be noted that Article 53, "Scope of the research activity," of the LOPDGDD does not impose that these must necessarily be carried out in relation to the data controller. Therefore, there is no obligation to investigate all the controllers that carry out the processing in question. Inspectors can obtain evidence by requesting information from the processor if they deem it appropriate.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

4.3 Affectation of the fundamental right to good administration

According to CAJASIETE, the accumulation becomes an obligation in case the absence of it could harm the rights of the administered, particularly those recognized in Article 24 of the Constitution, thus violating the right to good administration in accordance with Article 41 of the Charter of Fundamental Rights of the European Union.

In the previous allegations, the differences between the behaviors attributed to the Cajas Rurales have been motivated, and it has been stated that no type of defenselessness has been caused to CAJASIETE in the processing of this procedure, having had access to all the documents in the file. In fact, CAJASIETE has not justified any type of defenselessness, nor does it point out any specific fact by which it has been caused defenselessness.

Finally, it is reiterated that we are not dealing with the same facts, but rather with the same technical problem that caused a security incident in the information system of each of the responsible entities concerning their processing of personal data (all of them legally and economically independent from each other), which has produced a series of personal data security breaches, not a single personal data security breach, but a personal data security breach in each of the Cajas Rurales, which result in the alleged commission of a series of infringements by each of the different data controllers in relation to their processing of personal data and the rights and freedoms of their clients.

SECOND. THE NON-EXISTENCE OF GUILT OF CAJASIETE IN THE PRESENT CASE

CAJASIETE has invoked various arguments to justify the absence of guilt in its conduct.

Firstly, it states that it is outside the facts attributed to it, since in the present case, the processing is carried out through a data processor; which, in turn, is the one responsible for the entities against which the proceedings are directed; and that the personal data protection regulations not only impose obligations related to compliance with the principle of confidentiality and the adoption of necessary security measures on the data controller but, when the processing is carried out on behalf of the controller by a data processor, also on the latter.

In this regard, it is worth recalling that the figure of the data processor responds to the need to address phenomena such as the outsourcing of services by companies and other entities, so that in those cases where the data controller entrusts a third party with the provision of a service that requires the processor to process personal data on its behalf, the processing or the operations of the processing are carried out by the processor, in the name and on behalf of the controller, as if it were the latter who carries it out.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Therefore, the existence of a data processor depends on a decision made by the data controller, who may choose to carry out certain processing operations themselves or to contract all or part of the processing to a processor.

That is to say, the processor, in order to be one, does not hold any personal interest regarding the outcome of the processing subject to the contract, without prejudice to the economic compensation they receive for the service rendered, which is what occurs in the present case. Processors have no personal interest; they act on behalf of and in the name of the controller, following their orders and for their purposes, and this is what determines that they are processors from the outset.

This means that the data controller is responsible for actions contrary to the GDPR carried out by their processors, unless the latter have acted as true data controllers, deciding on the purposes and means of the processing, a situation that has not occurred in the present case.

Thus, the CJEU ruling of December 5, 2023, in case C-683/21, regarding the question of whether an administrative fine can be imposed under Article 83 of the GDPR on a data controller in relation to the processing operations carried out by a processor, determines that,

“83 Regarding, secondly, the question of whether an administrative fine can be imposed under Article

83 of the GDPR on a data controller in relation to the processing operations carried out by a processor, it is necessary to recall that, according to the definition in Article 4, point 8, of the GDPR, a processor is understood to be 'the natural or legal person, public authority, service, or other body that processes personal data on behalf of the data controller.'

84 Given that, as indicated in paragraph 36 of this judgment, a data controller is responsible not only for all personal data processing that they carry out themselves but also for the processing carried out on their behalf, an administrative fine can be imposed on that controller under Article 83 of the GDPR in a situation where personal data is subject to unlawful processing and where it is not the controller, but a processor they have engaged, who has carried out the processing on their behalf.

85 However, the responsibility of the data controller for the behavior of a processor cannot extend to situations where the processor has processed personal data for purposes that are their own or where they have processed such data in a manner incompatible with the framework or modalities of the processing as determined by the data controller or in a manner that cannot reasonably be considered to have been consented to by that controller. Indeed, in accordance with Article 28, paragraph 10, of the GDPR, the processor must, in that case, be considered a data controller with respect to that processing."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/58

To the above, we must add the recent SAN of February 8, 2024, rec. 0002250/2021, regarding TELEFÓNICA MÓVILES ESPAÑA S.A.U, in which it is determined that,

"Indeed, the appealing company is responsible for the processing, as it determines the purpose and means of the processing carried out for the purposes indicated in its Privacy Policy: 'At Movistar, we process customer or user data for the provision of the service, as well as for other purposes that the customer allows or authorizes in the terms informed in this Privacy Policy or in the specific Conditions of each Movistar Product or Service contracted.'

Whereas the companies ATENTO TELESERVICIOS ESPAÑA, S.A.U., CATHPONE-NET, S.L. and THADER TELECOMUNICACIONES S.L. are considered data processors.

What has been stated derives from the contracts signed by the acting party with the aforementioned companies.

...

Indeed, it has not been established that the mentioned companies, as data processors for the acting party, have determined the purposes and means of the processing, nor have they used the customers' data for their own purposes, nor have they interacted with interested parties outside the structure and commercial name of the appealing company, but rather they have acted under the name of the acting party to fulfill its purposes, using its systems to carry out operations with customers.

Therefore, it is not possible to invoke Article 28.10 of the GDPR for a presumed attribution of responsibility to the processors that would also imply the exoneration of the data controller, that is, of the company here appealing. On the other hand, according to the aforementioned contracts, there is a clause that passes on to them the possible sanctions that the plaintiff company may suffer for non-compliance with obligations regarding data protection."

On the other hand, the Guidelines 7/2020 of the EDPB on the concepts of "data controller" and "data processor" in the GDPR, version 2.0 Adopted on July 7, 2021, determine that,

"30 Following the line of the fact-based approach, the word 'determine' means that the entity that actually exercises a decisive influence over the purposes and means of the processing is the controller. Generally, the processing contract establishes who is the determining party (the data controller) and who is the party that follows the instructions (the data processor). Even when the data processor offers a service that is previously defined in a specific way, it must present the data controller with a detailed description of the service, and the controller must make the final decision on the approval of the manner in which the processing will be carried out and request any changes it deems necessary. Furthermore, the data processor cannot modify, at a later time, the essential

elements of the processing without the approval of the controller.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
36/58

...

39. The question is where to draw the line between the decisions reserved for the data controller and those that can be left to the discretion of the processor. It is evident that decisions regarding the purpose of the processing must always correspond to the controller.

40. As for the determination of the means, a distinction can be made between essential and non-essential means. Essential means are traditionally and inherently reserved for the data controller. These must be determined mandatorily by the data controller, although the determination of non-essential means can also be left to them. Essential means are closely linked to the purpose and scope of the processing, such as the type of personal data processed (“What data will be processed?”), the duration of the processing (“How long will the data be processed?”), the categories of recipients (“Who will have access to the data?”) and the categories of data subjects (“To whom do the processed personal data belong?”). In addition to being related to the purpose of the processing, essential means are closely linked to the question of whether the processing is lawful, necessary, and proportionate. Non-essential means are related to more practical aspects of the processing itself, such as the choice of a particular type of hardware or software or the decision on the details of security measures, which can be left to the processor.

41. Although decisions regarding non-essential means can be left to the processor, the controller must still stipulate certain elements in the contract with the processor: for example, regarding the security requirement, all measures required under Article 32 of the GDPR may be mandated. The contract must also establish that the processor will assist the controller in ensuring compliance with, for example, the provisions of Article 32. In any case, the data controller remains responsible for implementing appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is compliant with the Regulation (Article 24). To this end, the controller must take into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. For this reason, the data controller must have complete information about the means used, as this will allow them to make an informed decision in this regard. To enable the controller to demonstrate the legality of the processing, it is advisable to document, in the contract or another legally binding instrument between the controller and the processor, at least the necessary technical and organizational measures.

...

74. The GDPR establishes specific obligations that directly bind processors, as specified in section 1 of subsection II of these guidelines. It is possible to hold a processor accountable or sanction them when they fail to comply with such obligations or act outside or against the legal instructions of the controller.

...

80. Secondly, the processing must be carried out on behalf of a data controller, but not under their direct authority or control. Acting “on behalf of”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
37/58

“Acting on behalf of” someone means serving the interests of another and refers to the legal concept of “delegation.” In the case of data protection regulations, the role of the data processor is to apply the instructions given by the data controller, at least concerning the purposes of the processing and the essential elements of the means. The legitimacy of the processing under Article 6 and, if applicable, Article 9 of the Regulation derives from the activity of the controller, and the processor must only

process the data following the instructions given by the controller. Nevertheless, as previously indicated, the instructions of the data controller may leave some margin of discretion regarding how to best serve the interests of the controller, allowing the processor to choose the most appropriate technical and organizational means.

81. Acting "on behalf of" someone also means that the processor cannot carry out the processing for its own purposes. As stipulated in Article 28, paragraph 10, the data processor will violate the GDPR when it does not adhere to the instructions of the controller and begins to determine its own purposes and means of processing. In these cases, the data processor will be considered responsible in relation to that processing and may be sanctioned for failing to comply with the instructions of the controller." (the underlining is ours)

Well, in the specific case being examined, and in light of the documentation in the file, it is noted that, for the provision of IT services, RSI and CAJASIETE have entered into an "Individualized and Specific Service Provision Contract" with each of the entities with RSI.

Additionally, it has also entered into the framework of the previous contract the "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between CAJASIETE and RSI," an agreement related to CAJASIETE that was signed on 25/05/2018, by Mr. A.A.A., representing CAJASIETE (data controller).

In this regard, in this "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between CAJASIETE and RSI," CAJASIETE is identified as the data controller, and in this Data Protection clause, RSI is identified as the data processor. The "Data Processor" and the Entities are referred to as the "Data Controllers."

Furthermore, in this "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between CAJASIETE and RSI," this clause defines the processing activities that could be carried out by RSI on behalf of CAJASIETE, the type of information to be processed, and the categories of data subjects whose data could be processed.

Additionally, it specifies that the security measures that must be applied by RSI to ensure an adequate level of security in accordance with the provisions of Article 32 of the GDPR are those established in Annex B of the "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between CAJASIETE and RSI."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
38/58

We must also highlight that it is stated in section 6 of the Agreement on "Liability" that, "If the Processor, or where applicable, the contractors, breach this Agreement or the applicable regulations when determining the purposes and means of processing, they shall be considered responsible for the processing in relation to such processing.

In the event that a supervisory authority sanctions the Data Controller as a direct consequence of the Processor's failure to comply with the stipulations of this Agreement, the Processor shall indemnify the Data Controller as stipulated in the liability clause of the framework contract in force between the parties."

This implies, by contrary interpretation and in accordance with data protection regulations, the aforementioned judgments, and Guidelines 7/2020, that the data controller is responsible for the actions carried out by its data processor unless the latter determines the purposes and means, resulting in the fact that this last issue has not been proven in the proceedings conducted.

Therefore, according to the above, CAJASIETE and RSI are the responsible parties for the processing being carried out; they are the ones who have decided to entrust a data processor to carry it out on their behalf and for their account, they are the entity that has the true capacity to exercise control over the processing of personal data, who determines which personal data will be processed on their behalf and for their account, the why and how this data should be processed, as they define the purpose of the personal data processing that their activity entails and choose the means they deem appropriate. And in accordance with all of the above and for the specific case, CAJASIETE is responsible for the

infringement of the GDPR even if it has occurred within its data processor. This is independent of the actions and responsibilities that third parties may have incurred, as the negligence or illegal actions of third parties do not exclude their own.

In this regard, in the very Agreement of Initiation, it is indicated in section 4 relating to the Obligations of the Data Controller that:

“It is the responsibility of the data controller:

- a) To provide the Data Processor with the necessary data for the provision of the service
- b) If legally required, to carry out a data protection impact assessment of the processing operations to be carried out by the Data Processor.
- c) To carry out the necessary prior consultations.
- d) To ensure, prior to and throughout the processing, compliance with the GDPR by the Data Processor.
- e) To supervise the processing, including conducting inspections and audits.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/58

This is directly related to the principle of proactive responsibility of the data controller provided for in Article 5.2 of the GDPR, which states that “the data controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it (‘proactive responsibility’). This means that the controller must ensure the effective application of the principles of processing both at the time of determining the means of processing and during the processing itself, whether the processing of personal data is carried out directly by them or entrusted to a processor to carry it out on their behalf (for the purposes of data protection legislation, it is the same), through the articulation of a series of technical and organizational measures of all kinds, which must be subject to periodic review and updating. This implies that the aforementioned controller is the one who assumes their own responsibility by directing, reviewing, and coordinating the processing, including that of the personnel and that of the processor providing services to them.

Opinion 3/2010, from the Article 29 Working Party (WP29) -WP 173- issued during the validity of the repealed Directive 95/46/EC, but whose provisions are applicable today, states that the “essence” of proactive responsibility is the obligation of the data controller to implement measures that, under normal circumstances, ensure that the rules on data protection are complied with in the context of processing operations and to have available documents that demonstrate to data subjects and supervisory authorities what measures have been adopted to achieve compliance with data protection rules.

For these purposes, consideration is given to what is stated in the following Recital 74 of the GDPR:

“Responsibility of the data controller must be established for any processing of personal data carried out by them or on their behalf. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons.”

Completing the above and in development of Article 5.2 of the GDPR, Articles 24 and 25 of the same legal text must be cited, the latter indicating regarding “Data protection by design and by default” that the fundamental right to the protection of personal data is much more than mere technology, as its focus is on the risks to the rights and freedoms of data subjects arising from the processing of personal data,

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively

apply the principles of data protection, such as the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/58

data minimization, and integrate the necessary safeguards in the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

2. The data controller shall apply appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed...”

CAJASIETE seems to argue that the responsibility lies with the data processor with whom it signed a contract and under which it was obliged to implement the appropriate security measures according to the risk; however, it is worth noting that the personal data breach occurred as a result of CAJASIETE's decision (...), signing the corresponding data processing agreement with RSI where CAJASIETE established the appropriate conditions.

Moreover, this Agency has previously motivated that CAJASIETE has determined the purposes and means of the processing, that it is responsible for the processing, that it is responsible for the personal data breach in this case due to the processing actions carried out by its data processor on its behalf, and that it is subject to the obligations of the GDPR, especially regarding proactive responsibility.

This is the responsibility of CAJASIETE as it is the data controller and is obliged to integrate and deploy data protection within all that constitutes its organization, in all its areas of action, whether affecting its employees or its data processors. It must be kept in mind that ultimately the determining purpose is to guarantee the protection of the data subject, as the focus is on the risks to the rights and freedoms of the data subjects arising from the processing of personal data.

Therefore, the data controller must carry out a risk analysis of the rights and freedoms of natural persons in data processing, implementing appropriate technical and organizational measures to apply the principles of data protection and integrate the necessary safeguards in the processing, in order to comply with the requirements of the GDPR, being able to demonstrate that the processing is in accordance with the provisions of the aforementioned regulation. And in light of the principle of proactive responsibility (art. 5.2 GDPR), the data controller must be able to demonstrate that it has taken into account all the elements provided for in the GDPR.

Thus, all of this merely reflects a lack of diligence on the part of the investigated entity in ensuring adequate security relative to the risks of the data processing it carries out. In this regard, it should not be forgotten that the affected database contains personal data of thousands of customers, which constitutes large-scale processing, to which, in turn, access is obtained from web applications, that is, from the internet, with a very significant exposure surface, posing greater risks to the data subjects, which requires appropriate technical and organizational measures of all kinds, including security measures, suitable for this purpose and specifically aimed at ensuring that there is no unauthorized access to such personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/58

As has been demonstrated and argued throughout this sanctioning procedure, it is considered that appropriate security measures were not implemented in this case to ensure adequate security against the risk, even if there had not been a breach of personal data, the security of the personal data of the clients, which resulted in an illegitimate access to the personal data of the clients of CAJASIETE.

Therefore, liability is not being demanded solely as a consequence of a result caused by a cyberattack. It is another matter that has been highlighted in the event of a violation of the security of personal data. It is much more; it is a failure to comply with the obligations imposed by the GDPR.

Therefore, it is emphasized that the data controller must establish clear modalities for such assistance

in its relationship with the data processor and provide precise instructions to the data processor on how to comply with them adequately and document it in advance through a contract or in another (binding) agreement and also subsequently during the validity of the same and verify at all times during the execution of the contract its compliance in the manner established therein.

It suffices to bring to mind the content of the Supreme Court ruling STS 1562/2020, which states the following:

"In this regard, the Supreme Court ruling of June 5, 2004, which confirms, in cassation for the Unification of Doctrine, that of this AN of October 16, 2003, echoing what has been argued by this Chamber refers to the differentiation of two controllers based on whether the decision-making power is directed at the file or at the data processing itself. Thus, the file controller is the one who decides the creation of the file and its application, as well as its purpose, content, and use, that is, who has decision-making capacity over all the data recorded in that file. The data processor, however, is the subject to whom decisions regarding the specific activities of a particular data processing are to be attributed, that is, regarding a specific application. This would involve all those cases in which the decision-making power must be differentiated from the material execution of the activity that integrates the processing. With this, as also argued by the Supreme Court ruling of April 26, 2005 (cassation for unification of doctrine 217/2004), the Spanish legislator aims to adapt to the requirements of Directive 95/46/EC, which aims to provide a legal response to the phenomenon, which is becoming increasingly frequent, of the so-called outsourcing of IT services, where multiple operators act, many of them insolvent, created with the aim of seeking the impunity or irresponsibility of those who follow them in the subsequent links of the chain. Currently, the new Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data (which repeals Directive 95/46/EC, and applies directly from May 25, 2018) also distinguishes between the figures of the controller and the processor. The former is defined in paragraph 7) of Article 4 as "a natural or legal person (...) who determines the purposes and means of the processing." And the processor in paragraph 8) of the same Article 4 as one who "processes personal data on behalf of the data controller."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/58

This is in relation to Articles 24 and 28 of the same European Data Protection Regulation. The data controller and the data processor are undoubtedly responsible for violations regarding data protection, within this new regulatory framework, in accordance with the provisions of Article 82.2 of the aforementioned Regulation (EU) 2016/679, which states: Any controller participating in the processing operation shall be liable for damages caused if that operation does not comply with the provisions of this Regulation. A processor shall only be liable for damages caused by processing when it has not complied with the obligations of this Regulation specifically directed at processors or has acted outside or against the lawful instructions of the controller. It follows from all of the above that the involvement, in this case, of a data processor ZZZZ does not exempt the entity XXXX, now the appellant, from liability, despite the strength of the clauses contained in the contract and its annex signed by both companies (proven facts 9 and 10) regarding the personal data processed for the purpose of carrying out an advertising campaign concerning car and motorcycle insurance marketed by XXXX, ultimately benefiting said XXXX, being the acting entity that ultimately determines the purposes and means of the aforementioned data processing, and therefore cannot be exempted from liability.

The Supreme Court continues, in relation to the possible exemption of liability alleged regarding what was signed in the "data processor" contract, as follows:

"The sanctioned conduct of obstruction or impediment by XXXX of its client's exercise of the right to object to the processing of their data is manifested in that said company did not adopt any measures or precautions to prevent the sending of advertisements to its client's email addresses by those companies to which it entrusted the execution of the advertising campaigns.

The adoption of the necessary measures or precautions to ensure the effectiveness of the right to

object to the processing of their data by XXXX, as the data controller, remains in effect even if the advertising campaigns are not carried out based on data from its own files, but rather with databases from other companies contracted by XXXX, and in this case, it was established that the appellant did not communicate to the companies with which it contracted the provision of advertising services the complainant's objection to receiving advertisements from the Mutual, nor did it ultimately adopt any provision to ensure the exclusion of its client from the advertising mailings contracted with third parties."

Regarding the application of the principle of culpability in the field of sanctioning law regulated by the GDPR, the investigated entity brings up the doctrine established by the CJEU ruling of December 5, 2023 (case C-807/21, Deutsche Wohnen SE and Staatsanwaltschaft Berlin).

Well then, one might ask what the parameters of due diligence that the investigated entity should have observed in relation to the

43/58

examined conduct. The response is that the diligence that should have been observed is the one necessary to fulfill the obligations imposed by Articles 5.2, 24, and 25 of the GDPR, in light of the doctrine of the National Court and the jurisprudence of the Supreme Court.

The SAN of October 17, 2007 (rec. 63/2006) is fully applicable to the case, which, after referring to the fact that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, states:

"(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

Furthermore, the National Court in matters of personal data protection has declared that "simple negligence or failure to comply with the duties imposed by law on those responsible for files or data processing to exercise extreme diligence is sufficient..." (Judgment of the National Court of June 29, 2001).

Regarding the allegation made that the personal data breach occurred within the framework of the data processing for which RSI was responsible, to the extent of carrying out the investigative actions exclusively with that entity, it should be noted that the preliminary investigative actions are precisely carried out to clarify the facts and circumstances of what happened, gathering more information in order to determine whether or not there is a possible infringement of the data protection regulations. In this sense, the initiation of preliminary investigations and their execution, a power of the AEPD, does not prejudice anything, but allows for the determination of the events that occurred and the gathering of necessary information wherever it may be found to determine whether there are indications of infringement or not. Even after such investigation, it may be that the actions are archived because, based on the information gathered, there are no indications of infringement. This, in the present case, has not happened.

Consequently, the allegations must be dismissed since the investigated entity has infringed the obligations imposed by the GDPR in its capacity as the controller of the processing carried out on its behalf and for its account, in relation to the responsibilities required of every data controller by Article 24 of the GDPR. Therefore, the allegations must be dismissed, emphasizing that the arguments presented do not undermine the essential content of the infringement declared nor do they constitute sufficient justification or exculpation.

THIRD. ON THE IMPACT ON THE PRINCIPLES OF SANCTIONING LAW DERIVED FROM THE INTERPRETATION MADE BY THE AEPD

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/58

CAJASIETE considers that it has not committed any infringement of the Data Protection regulations, much less the simultaneous infringement of Articles 5.1 f) and 32 of the GDPR, as the triple identity of subject, fact, and protected legal interest is present. There is no doubt that in this case the principle of non bis in idem should be applied, imposing only the sanction for Article 5.1.f) as it is the more serious of the two alleged infringements.

And in the event that the AEPD recognizes the violation, it should subsidiarily recognize a medial concurrence as one of the infringements is subsumed and embedded within the other, according to what is provided in Article 29.5 of the LRJSP, "When the commission of one infringement necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed."

"1. Violation of the principle of non bis in idem in the application of Articles 5.1 f) and 32 of the GDPR"

In this regard, and in relation to this allegation made by CAJASIETE against the initiation agreement, it should be noted that since the filing of the initially alleged infringement of Article 32 of the GDPR has been proposed, it is no longer necessary to respond to these allegations, as the accusation of Article 5.1.f) of the GDPR no longer coincides with Article 32 of the GDPR.

FOURTH. ON THE ALLEGED VIOLATION OF ARTICLE 32.1 OF THE GDPR.

CAJASIETE has stated that the AEPD considers the alleged violation of Article 32 of the GDPR to be "evidenced," that is, it considers the alleged insufficiency of the security measures adopted to be evident as a result of the occurrence of the personal data breach, making exclusive reference to the report on the breach contained in the administrative file, while neglecting in the initiation agreement all the measures adopted as well as the audit carried out, and that there is a misinterpretation of what occurred in the RSI systems, indicating that subsequent to the aforementioned audit, modifications had been introduced in the SSO process for access to the NBE.

Well, as indicated, upon reviewing the allegations made by the responding party, and in consideration of them, reviewing the documentation in the administrative file and that provided by the responding party, it is evident that all the technical and organizational security measures whose absence has been proven have had a direct impact on the personal data breach, without there being a violation, in this specific case, of Article 32 of the GDPR as the absence of other independent technical and organizational security measures from the personal data breach has not been substantiated.

Regarding the sufficiency of the security measures, in relation to the non-compliance with Article 5.1.f) of the GDPR, we refer to what has already been indicated in the legal basis IV of this resolution proposal, which explains and details why they were neither sufficient nor appropriate.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/58

Furthermore, we will indicate that it is true that it is recorded that, both prior to and subsequent to the security incident, the investigated entity conducted audits and reviews by third-party specialists aimed at detecting vulnerabilities related to the security of information systems; but it is also true that despite the existence of such investigations, controls, and verifications, they were unable to locate and reveal the existing vulnerabilities, as evidenced by the established facts.

CAJASIETE claims that RSI holds various certifications in the field of security, referenced in the third established fact of this resolution proposal.

Article 28 of the GDPR, on the Processor, in its paragraph 5, states that:

"5. The adherence of the processor to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may be used as an element to demonstrate the existence of sufficient guarantees referred to in paragraphs 1 and 4 of this article."

In this regard, to demonstrate that processors offer the suitability and guarantees required by the GDPR, adherence to a certification mechanism can be used as an additional element to establish the existence of sufficient guarantees to implement appropriate technical and organizational measures to protect personal data.

This is because, in addition to the fact that a processor has been certified in data protection, this

certification does not absolutely prove that the sufficient guarantees in relation, in this case, to the provision of Article 28.1 of the GDPR, have been implemented and are operating effectively throughout the entire processing cycle and during the time this processing is taking place.

In the area of data protection, such instruments are voluntary compliance mechanisms that establish specific rules aimed at contributing to the correct application of the GDPR and the LOPDPGDD.

According to the GDPR, the data controller must adopt appropriate measures, including the selection of processors, in such a way as to ensure and be in a position to demonstrate that the processing is carried out in accordance with the GDPR (principle of active accountability).

It is true that the certifications that RSI appears to hold are cited in the processing agreement; however, let us note that all the certifications listed in the third established fact are not the certifications provided for in either Article 28 or Article 42 of the GDPR; they are not data protection certifications, but rather certifications related to information security or other obligations that must be fulfilled by the controller or the processor based on regulations other than data protection.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

46/58

Thus, in the "Amendment Agreement of the Data Protection Clause of the Service Provision Contracts," signed between CAJASIETE and RSI, in its "Annex B - Security Measures to the Amendment Agreement of the Data Protection Clause of the Service Provision Contracts," it is indicated that RSI holds the following certifications:

(...)

Furthermore, its mention in the service contract is not accompanied by the certification itself for the purposes of verifying that it has indeed been certified and to see exactly what it is certified for, at what moment it was certified, and whether at the time of the personal data breach the certification was still valid (since certifications have a validity period), this certification is not for data protection.

In this regard, the report of the Legal Cabinet 170/2018 of the AEPD establishes the difference between information security and the protection of personal data. Thus, it is indicated that,

"Prior to analyzing the specific issue raised in the consultation, this Legal Cabinet finds it appropriate to make a prior reference to the substantive and jurisdictional differentiation that exists between the field of information security and that of the protection of personal data.

Regarding information security, it encompasses the set of techniques and measures aimed at ensuring the confidentiality, integrity, and availability of information and data important for any organization, regardless of their format. (...)

On the contrary, the protection of personal data of individuals is configured as a true fundamental right that finds its basis in Article 18.4 of the Spanish Constitution, according to which "the law will limit the use of computing to guarantee the honor and personal and family privacy of citizens and the full exercise of their rights." This has been recognized by our Constitutional Court, highlighting in Judgment 94/1998, of May 4, that the aforementioned Article 18.4 "not only entails a specific instrument for the protection of citizens' rights against the tortious use of computing technology, but also enshrines an autonomous fundamental right to control the flow of information concerning each person - to 'privacy' according to the neologism stated in the Explanatory Memorandum of the LORTAD - whether or not it belongs to the strictest realm of intimacy, in order to preserve the full exercise of their rights."

This is reflected in the Preamble of the Organic Law Project on Personal Data Protection and Guarantee of Digital Rights, which for its clarity is transcribed below:

"The protection of individuals in relation to the processing of personal data is a fundamental right protected by Article 18.4 of the Spanish Constitution. Thus, our Constitution was a pioneer in recognizing the fundamental right to the protection of personal data when it stipulated that 'the law...

47/58

will limit the use of information technology to guarantee the honor and personal and family privacy of citizens and the full exercise of their rights." This echoed the work developed since the late 1960s in

the Council of Europe and the few legal provisions adopted in countries in our environment. The Constitutional Court stated in its Judgment 94/1998, of May 4, that we are faced with a fundamental right to data protection, which guarantees individuals control over their data, any personal data, and its use and destination, to prevent the illicit trafficking of such data or harm to the dignity and rights of those affected; thus, the right to data protection is configured as a citizen's power to oppose the use of certain personal data for purposes other than those that justified its acquisition. In its Judgment 292/2000, of November 30, it considers it an autonomous and independent right that consists of a power of disposition and control over personal data that empowers individuals to decide which of those data to provide to a third party, whether the State or a private individual, or which data this third party may collect, and that also allows the individual to know who possesses that personal data and for what purpose, being able to oppose such possession or use.

At the legislative level, the specification and development of the fundamental right of protection for individuals in relation to the processing of personal data took place initially through the approval of Organic Law 5/1992, of October 29, regulating the automated processing of personal data, known as LORTAD. Organic Law 5/1992 was replaced by Organic Law 15/1999, of December 5, on the protection of personal data, in order to transpose Directive 95/46/EC of the European Parliament and of the Council, of October 24, 1995, regarding the protection of individuals in relation to the processing of personal data and the free movement of such data. This organic law represented a second milestone in the evolution of the regulation of the fundamental right to data protection in Spain and was complemented by an increasingly abundant jurisprudence from the contentious-administrative jurisdictional bodies.

On the other hand, it is also included in Article 8 of the Charter of Fundamental Rights of the European Union and in Article 16.1 of the Treaty on the Functioning of the European Union. Previously, at the European level, the aforementioned Directive 95/46/EC had been adopted, which aimed to ensure that the guarantee of the right to personal data protection did not constitute an obstacle to the free movement of data within the Union, thus establishing a common space for the guarantee of the right that simultaneously ensured that in the case of international data transfers, their processing in the destination country was protected by safeguards adequate to those provided for in the directive itself." And in this same sense, Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the protection of individuals in relation to the processing of their personal data and on the free movement of such data, which repeals Directive 95/46/EC (General Data Protection Regulation, GDPR), aims to "protect the fundamental rights and freedoms of natural persons and, in particular, their right to the protection of personal data" (Article 1.2), highlighting in its

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/58

Considering 1 that "the protection of natural persons in relation to the processing of personal data is a fundamental right" and in its Considering 10 that "to ensure a uniform and high level of protection for natural persons and to eliminate obstacles to the free movement of personal data within the Union, the level of protection of the rights and freedoms of natural persons with regard to the processing of such data must be equivalent in all Member States. It must be ensured throughout the Union that the application of the rules for the protection of the fundamental rights and freedoms of natural persons in relation to the processing of personal data is consistent and homogeneous."

Consequently, the right to the protection of personal data of natural persons is a fundamental right and, therefore, situated at the highest level of legal protection, which is currently regulated directly by community legislation, establishing the aforementioned GDPR a set of principles, rights, obligations, and an organizational structure aimed at guaranteeing this fundamental right. Among these, the security of information appears as an additional obligation for the controllers and processors, who must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which will include, among other factors, "the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services" and "the ability to restore the

availability and access to personal data quickly in the event of a physical or technical incident" (Article 32.2. b) and c) of the GDPR).

Therefore, there is no doubt that the guarantee of the security of personal data acquires special significance regarding its protection, but without being limited exclusively to the field of security of that information, as the protection of personal data has a much broader scope that encompasses, as we said, a set of principles, rights, and obligations that are much wider.

This issue is substantial since the certification mentioned in the contract of engagement does not serve as an element to "demonstrate the existence of the sufficient guarantees referred to in paragraphs 1 and 4" of Article 28 of the GDPR, as it does not pertain to data protection. The difference in focus between mere information security and data protection is extremely important, as while the focus of the former is exclusively on the security of information, the risk-based approach of the GDPR (which is much broader as it focuses on the risks to the rights and freedoms of data subjects arising from the processing of personal data) is centered on natural persons, with security being just one more obligation within those of the GDPR to achieve the protection of natural persons in the terms of the recitals, namely, 1 and 10, as well as in accordance with the provisions of Article 1 of the GDPR. Within the management of compliance with the GDPR lies risk management, on which the security of information pivots and not the other way around.

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
49/58

CAJASIETE claims that the security measures initially implemented by RSI are included in the service agreement signed with RSI and that the attackers may have legitimate credentials for access, and that the attack is not due to weaknesses in the implemented systems.

As a preliminary matter, we must refer to the established facts and the description of the personal data breach to understand how and why the personal data breach occurred.

Regarding the security measures outlined in the "Amendment Agreement to the Data Protection Clause of the Service Provision Contracts," when referring to the security measures, there is a reference to those listed in Annex B - Security Measures to the Amendment Agreement to the Data Protection Clause of the Service Provision Contracts.

Well, from a detailed examination of the citation of the same, since we are unaware of the description of the specific measures implemented, we can again verify that they are measures that refer generally to information security and not to data protection (...). A policy is a central and guiding instrument of an organization in which the responsible party addresses its objectives and establishes procedures, resources, and mechanisms to carry it out, which requires subsequent detailed development. It is not the same to address mere information security as it is to address the protection of a fundamental right such as data protection, considering the focus and purpose of each of them.

Furthermore, the fact that a list of measures appears in a service agreement (also in this specific case, information security measures) does not imply that they guarantee appropriate security as determined by Article 5.1.f) of the GDPR, because it must be based on the focus on the protection of the rights and freedoms of the data subjects, and the implemented measures do not necessarily serve to fulfill such an objective if they have not been designed and implemented from the perspective required by the GDPR.

FIFTH. ON THE ALLEGED VIOLATION OF ARTICLE 5.1.f) OF THE GDPR.

CAJASIETE considers the contradiction in which the Initial Agreement incurs by stating that "the identification of a personal data breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the controllers and processors and the security measures applied," when subsequently it understands that Article 5.1.f) has been violated as a consequence of the mere fact that the breach has occurred.

On this particular matter, we refer to legal basis IV explaining the concurrence of the violation of Article 5.1.f) of the GDPR in this specific case, where it is detailed that the violation has not been committed

merely due to the result of loss of confidentiality, even though it is a result-based violation.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
50/58

The Judgment of the Constitutional Court (STC) 292/2000, in its analysis of the "content" of the fundamental right to data protection, refers to the power of disposition and control that pertains to the data subject over the possible use or uses of their data by a third party. The seventh legal basis states: "[...] it turns out that the content of the fundamental right to data protection consists of a power of disposition and control over personal data that enables the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which this third party may collect, and that also allows the individual to know who holds that personal data and for what purpose, being able to oppose that possession or use. These powers of disposition and control over personal data, which constitute part of the content of the fundamental right to data protection, are legally specified in the authority to consent to the collection, obtaining, and access to personal data, their subsequent storage, as well as their possible use or uses by a third party, whether the State or a private individual." The obligation of confidentiality that Article 5.1.f) of the GDPR imposes on the data controller is an obligation of result, such that for the provision to be considered violated, the confidentiality of the data must be breached.

As specified by the Supreme Court ruling of 15/02/2022 (cassation appeal 7359/2020):

"The obligation to adopt the necessary measures to ensure the security of personal data cannot be considered an obligation of result, which implies that once a leak of personal data to a third party occurs, there is liability regardless of the measures adopted and the activity carried out by the data controller or processor.

In obligations of result, there is a commitment to fulfill a specific objective, ensuring the achievement or proposed result, in this case, guaranteeing the security of personal data and the non-existence of leaks or security breaches (...)

It should be noted that the data controller incurs in contradiction when, on the one hand, it considers that there has been no violation of data protection regulations and believes that everything should be redirected to the filing of the case, while on the other hand, it confirms and indicates that it is evidenced in the file "that the attacker could access the data, but in no case alter it, ..."; (...)

(...)

Regarding the allegations reiterated by the respondent that the infringements attributed concerning Article 5.1.f) and 32 of the GDPR are identical since we are faced with the same fact subject to double attribution, we refer to what has already been indicated in previous legal grounds regarding the proposal to file the infringement of Article 32 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

51/58

In light of the above, it is established that CAJASIETE has violated the principle of confidentiality and integrity of the data, a principle enshrined in Article 5.1.f) of the GDPR, an infringement classified under Article 83.5.a) of the GDPR.

SIXTH. ON THE ALLEGED VIOLATION OF ARTICLE 33 OF THE GDPR

Regarding the allegations made by the complainant concerning the attribution of Article 33 of the GDPR, a response is no longer necessary, as, as stated in the proven facts and in the preceding legal grounds, the filing of the initially attributed infringement is proposed in light of the specific circumstances of the case previously expressed.

SEVENTH. VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY IN THE DETERMINATION OF SANCTIONS.

CAJASIE TE has argued that if it is considered that there has been a violation of data protection regulations, particular consideration should be given in determining the sanction that may be imposed by applying the principle of proportionality.

It should be noted that Article 83.1 of the GDPR provides that “Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

Fines, therefore, as deduced from the invoked provision, must be effective, proportionate, and dissuasive to achieve the intended purpose of the GDPR.

It is true that for this system to function with all its guarantees, it is necessary for several elements to be deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case as permitted by the GDPR itself - would undermine the effectiveness of the system, losing its meaning, its teleological purpose, the will of the legislator, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. And in this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished and it would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms. Regarding the principle of proportionality of sanctions, the National Court in numerous judgments has indicated that the principle of proportionality

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/58

cannot escape judicial control, as the margin of appreciation granted to the Administration in the imposition of sanctions within the legally established limits must be developed by weighing, in any case, the concurrent circumstances, in order to achieve the necessary and due proportion between the alleged facts and the responsibility required, given that any sanction must be determined in accordance with the severity of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the act. Thus, proportionality constitutes a normative principle that is imposed on the Administration and that reduces the scope of its sanctioning powers.

In accordance with the circumstances present in this case, which have been meticulously and appropriately evaluated, this resolution does not violate the principle of proportionality in the determination of the imposed sanctions, resulting in a balanced and proportionate response to the severity of the infringement committed, the importance of the facts, as well as the circumstances taken into account to graduate the sanction, without any reasons being appreciated that further justify the reduction made, especially considering the amount to which such sanctions may ascend in accordance with Article 83.5 of the GDPR, which provides for the infringement of Article 6.1 of the GDPR, “with administrative fines of up to €20,000,000 or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount.”

In this case, the entity under investigation is a large company within its sector of activity; according to the proven fact twenty-first, its turnover (gross margin) during the financial year 2022 amounted to (...) €, resulting in the fine imposed for the infringement of Article 5.1.f) of the GDPR amounting to 55,000 euros, which would be in the lower range of the possible administrative fine that could be imposed on the data controller and far from the maximum of 4% of the total annual global turnover of the previous financial year considering the turnover.

- CAJASIE TE considers regarding the circumstance derived from the nature, severity, and duration of the infringement that the mere reference to the provision subject to the infringement is taken as an aggravating factor.

However, such an argument cannot be accepted as inconsistent; in fact, what is being highlighted is that the infringement of Article 5.1.f) affects one of the basic principles on which the data protection regulations for personal data are based, confidentiality, and this violation is exacerbated and aggravated by the number of individuals affected by the incident, the damages and harms caused (irreversible loss of power and control over personal data by customers) and its duration, as (...).

- CAJASIETE considers regarding the intentionality or negligence in the infringement that the lack of diligence in its actions is due exclusively to its condition as a financial entity and, in truth, the aforementioned assertion is surprising.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/58

Considering that CAJASIETE's conduct involves the element of culpability, which is essential to demand sanctioning responsibility, in this case, it is specifically manifested in a very serious lack of diligence in complying with the principle of confidentiality of personal data, as has been demonstrated throughout the procedure.

RSI has pointed out that:

“(…)”

(…), all of them natural persons. All of them were notified of the security incident that occurred.

Furthermore, the lack of diligence demonstrated in the infringing conduct for which it is held responsible must be classified as very serious; CAJASIETE is obliged under Article 5.2 of the GDPR to undertake the appropriate activity to comply with the principles of data protection, specifically, the principle of confidentiality, and to be in a position to demonstrate its compliance.

- CAJASIETE considers that taking its banking activity into account as an aggravating factor is a kind of objective aggravation; firstly, it is not a matter related to the specific activity carried out by a particular entity, but rather the aggravating factor provided for in Article 76.2.b) of the LOPDGDD operates when the infringer's activity is linked to the processing of personal data, and it is obvious that, in relation to the present data controller, its activity, in this specific banking case, is clearly linked, directly, to multiple processing of personal data affecting thousands of clients.

In this regard, the National Court has considered it correct to appreciate the aggravating factor provided for in Article 76.2.b) of the LOPDGDD whenever the aforementioned link exists, and it has considered this in numerous rulings, including the ruling dated 04/07/2024, (rec. 382/2022) which states regarding the cited circumstance that:

“As well, the aggravating factor of the continued nature of the infringement, included in Article 76.2.a) of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, can also be appreciated, referring to it when we analyze the application of the GDPR to the infringement at hand. As well as the appreciation of the link between the infringer's activity and the processing of personal data (Article 72.2.b) of Organic Law 3/2018, of December 5), due to the fact that the activity of the appellant is linked to the processing of data from both clients and third parties; this cited link is well-known since the entity, due to its activity, is in constant contact with clients and third parties handling a large volume of data, which imposes a greater duty of diligence” (the emphasis is ours).

Finally, CAJASIETE considers that the AEPD, in modulating its responsibility, has not taken into account elements to mitigate it, such as evidentiary elements that demonstrate compliance with the highest standards in terms of security, nor the fact that the measures adopted were subjected to a system of periodic auditing or that RSI resolved the vulnerability that constituted the security breach; it suffices to refute what has been stated by referring to the content of the proven facts and regarding the last issue raised, to refer to what the data processor itself indicates in its writing notifying the personal data breach, dated 14/12/2022, and the writing of 10/01/2023 transferring the final report, in which it responds to the following questions:

- Could the breach have been avoided by adopting any additional security measures?

Yes

- Did the incident occur due to any failure, deficiency, or non-compliance with implemented security measures?

Yes

And regarding the actions taken after the incident:

- Have you adapted/improved your security procedures and policies?

No

Therefore, the allegation made regarding the violation of the principle of proportionality cannot be accepted.

In light of the above, the following

PROPOSAL FOR RESOLUTION

Is issued that the Director of the Spanish Agency for Data Protection sanctions CAJASIETE, CAJA RURAL S.C.C., with NIF (...), for the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the GDPR, with a fine of €55,000 (fifty-five thousand euros).

That the Director of the Spanish Agency for Data Protection archives CAJASIETE, CAJA RURAL S.C.C., with NIF (...), for the infringement of Article 32.1 of the GDPR, classified under Article 83.4.a) of the GDPR.

That the Director of the Spanish Agency for Data Protection archives CAJASIETE, CAJA RURAL S.C.C., with NIF (...), for the infringement of Article 33.1 of the GDPR, classified under Article 83.4.a) of the GDPR.

Likewise, in accordance with the provisions of Article 85.2 of the LPACAP, it is informed that it may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed sanction, which will entail a reduction of 20% of the amount thereof. With the application of this reduction, the sanction would be established at €44,000 (forty-four thousand euros) and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures. The effectiveness of this reduction will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the sanction.

In the event that it opts to proceed with the voluntary payment of the amount specified above, in accordance with the provisions of the aforementioned Article 85.2,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/58

must be made effective by depositing it into the restricted account No. IBAN:

ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the bank CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason, for voluntary payment, for the reduction of the amount of the sanction. Furthermore, the proof of payment must be sent to the General Sub-Directorate of Inspection to proceed with closing the file.

In virtue of this, you are notified of the above, and the procedure is made known to you so that within TEN DAYS you may present any arguments you consider in your defense and submit any documents and information you deem pertinent, in accordance with Article 89.2 of the LPACAP.

D.D.D.

INSPECTOR/INSTRUCTOR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/58

ANNEX

Index of file EXP202400058

(...)

>>

SECOND: On December 20, 2024, the respondent has proceeded to pay the sanction in the amount of 44,000.00 euros, making use of the reduction provided for in the resolution proposal transcribed above.

THIRD: The payment made entails the waiver of any action or appeal in the administrative route against the sanction, in relation to the facts referred to in the resolution proposal.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely pecuniary or when a pecuniary sanction and another non-pecuniary sanction can be imposed but the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely pecuniary, the competent authority to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which may be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure and their effectiveness will be conditioned on the withdrawal or waiver of any action or appeal in the administrative route against the sanction. The percentage of reduction provided in this section may be increased by regulation."

III

Voluntary payment

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified resolution proposal allowed for the voluntary payment of the proposed sanction, which would imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be established at 44,000.00 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Following the aforementioned resolution proposal, and before a resolution was issued by this authority, the respondent, on December 20, 2024, proceeded to make the voluntary payment, availing themselves of the 20% reduction and waiving any action or appeal in the administrative route.

It should be noted that, in accordance with the provisions of the LPACAP, as well as the jurisprudence of the high court in this matter, the exercise of voluntary payment by the presumed responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and any others arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the

graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the resolution proposal transcribed in this resolution.

The sum of the aforementioned amounts yields a total of 55,000.00 euros.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
58/58

After the responding party proceeded with the prompt payment, although without acknowledgment of responsibility, it is hereby resolved, pursuant to Article 85 of the LPACAP, to reduce the total amount mentioned by 20%, which results in a final amount of 44,000.00 euros.

SECOND: DECLARE the termination of procedure EXP202301118, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: NOTIFY this resolution to CAJASIETE, CAJA RURAL SOCIEDAD COOPERATIVA DE CREDITO.

FOURTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment on the withdrawal or renunciation of any action or administrative appeal by the present authority, the express renunciation manifested by the responding party is accepted, and consequently, the filing of a discretionary appeal for reconsideration against this resolution is not permitted, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since no administrative appeal is possible due to the express renunciation, this resolution will be fully enforceable from the notification thereof.

However, in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative process may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not have knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to vacancy in the position of Presidency and Deputy

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es